Data Retention Policy

Effective Date: January 1, 2026
Last Updated: January 1, 2026

1 Purpose and Scope

This Data Retention Policy governs the collection, storage, and deletion of personal data and business records within our invoice and payment management application ("the Service"). This policy ensures compliance with the General Data Protection Regulation (GDPR) and German data protection laws (BDSG).

2 Legal Basis and Compliance

Our data retention practices comply with:

- EU General Data Protection Regulation (GDPR)
- German Federal Data Protection Act (Bundesdatenschutzgesetz - BDSG)
- German Commercial Code (Handelsgesetzbuch - HGB)
- German Fiscal Code (Abgabenordnung - AO)

3 Data Categories and Retention Periods

3.1 Customer Master Data

Data Type: Names, addresses, contact information, customer IDs

Retention Period: Duration of business relationship plus 3 years, or as required by statutory retention obligations

Legal Basis: Contract performance (Art. 6(1)(b) GDPR), legitimate interest (Art. 6(1)(f) GDPR)

3.2 Invoice Data

Data Type: Invoice numbers, dates, line items, amounts, tax information

Minimum Retention Period: 10 years from end of calendar year (§ 147 AO, § 257 HGB)

Legal Basis: Legal obligation (Art. 6(1)(c) GDPR)

Note: This is a mandatory retention period under German tax and commercial law that supersedes user deletion requests

3.3 Payment Transaction Data

Data Type: Payment amounts, dates, payment methods, transaction references

Minimum Retention Period: 10 years from end of calendar year (§ 147 AO)

Legal Basis: Legal obligation (Art. 6(1)(c) GDPR)

3.4 Communication Records

Data Type: Email correspondence, support tickets, notes

Retention Period: 3 years after last contact or as needed for ongoing support

Legal Basis: Legitimate interest (Art. 6(1)(f) GDPR)

3.5 Account and Authentication Data

Data Type: User credentials, login history, session data

Retention Period: Duration of account existence plus 30 days

Legal Basis: Contract performance (Art. 6(1)(b) GDPR)

3.6 Application Logs (Vercel, Convex)

Data Type: Access logs, error logs, system logs

Retention Period: 90 days

Legal Basis: Legitimate interest (Art. 6(1)(f) GDPR) for security and troubleshooting

3.7 API Usage Data (Claude API)

Data Type: API requests, prompts, responses (if stored)

Retention Period: 30 days maximum, unless part of business records

Legal Basis: Legitimate interest (Art. 6(1)(f) GDPR)

Note: Personal data should be minimized in API calls when possible

4 Data Processing Locations

- **Application Hosting:** Vercel (locations as per service agreement)
- **Database:** Convex (locations as per service agreement)
- **AI Processing:** Anthropic Claude API (US-based processing)
- **Data Transfers:** Standard Contractual Clauses (SCCs) are in place for non-EU transfers

5 User Rights and Exceptions

5.1 Right to Erasure

Users may request deletion of their data at any time. However, we must inform users that:

- Invoice and payment data must be retained for 10 years due to German tax law (§ 147 AO)
- During this period, we will restrict processing to the minimum required by law
- After statutory retention periods expire, data will be permanently deleted within 30 days

5.2 Right to Restriction

Users can request restriction of processing during the mandatory retention period. Restricted data will be:

- Marked as restricted in our systems
- Accessible only for compliance purposes
- Not used for any operational purposes

6 Data Deletion Procedures

6.1 Automated Deletion

- Session data: Automatically deleted after 24 hours of inactivity
- Application logs: Automatically purged after 90 days
- Expired data: Monthly automated review and deletion of data past retention periods

6.2 Manual Deletion

- User-initiated account deletion triggers immediate deletion of non-statutory data

- Statutory data is flagged for deletion after retention period expires
- Quarterly verification of deletion completeness

6.3 Secure Deletion Standards

All deletions follow these standards:

- Database records are permanently removed, not just flagged
- Backups containing deleted data are rotated out within 90 days
- API providers (Anthropic) are instructed not to retain data per their terms

7 Data Minimization

We implement the following minimization practices:

- Collect only data necessary for invoice and payment matching
- Avoid sending personal data to Claude API when possible; use anonymization where feasible
- Regular audits to identify and remove unnecessary data fields
- Limit AI processing to operational necessity only

8 Third-Party Data Processors

Processor	Purpose	Location	Safeguards
Vercel	Hosting	Global CDN	SCCs, Privacy Shield successor
Convex	Database	Per service terms	SCCs, encryption
Anthropic	AI processing	USA	SCCs, data processing agreement

Each processor has signed a Data Processing Agreement (DPA) compliant with Art. 28 GDPR.

9 Backup Retention

- **Backup Frequency:** Daily incremental, weekly full backups
- **Backup Retention:** 90 days
- **Backup Location:** Same regions as production data
- **Note:** Deleted data may persist in backups for up to 90 days before complete removal

10 Policy Review and Updates

This policy is reviewed annually or when:

- Legal requirements change
- Business processes significantly change
- Data protection authorities issue relevant guidance

Users will be notified of material changes via email and in-app notification.

11 Contact Information

For questions about this policy or to exercise your data rights:

Data Protection Officer/Contact:
leoj.de - Leopold Jofer
Heisenbergstraße 7, 85748 Garching b. München, Deutschland
mail@leoj.de

Supervisory Authority:
Depending on your location in Germany, contact your relevant State Data Protection Authority (Landesdatenschutzbehörde) or for federal matters:
Der Bundesbeauftragte für den Datenschutz und die Informationsfreiheit (BfDI)
Graurheindorfer Str. 153
53117 Bonn, Germany

12 Statutory Retention Requirements Summary

For transparency, we retain the following data due to German law, even after account deletion:

- **10 years:** Invoices, accounting records, payment transactions (§ 147 AO, § 257 HGB)
- **6 years:** Business correspondence, received commercial letters (§ 257 HGB)

These periods begin at the end of the calendar year in which the record was created.

Document Version: 1.0
Approved by: Leopold Jofer
Next Review Date: January 1, 2027